

100 Days of Azure DevOps

Day 63 Handout — The Entra app is the identity; the Azure DevOps service connection is the badge that uses it

7 - Security, Compliance & Governance · Personal lab only · Educational content · Not a sales pitch

Architecture A — three objects people mash into one name

Object	Where it lives	Job
App registration	Entra (Day 61). Client ID	Application identity. May hold federated credentials or a secret
Service principal	Entra enterprise app in the tenant	What Azure RBAC is assigned to (Contributor on one RG)
Service connection	Azure DevOps Project Settings	How a pipeline job gets a token to call Azure. Not an Entra blade
Client secret auth	Password on the app. Stored by ADO	Long-lived. Expires at 2am. Postcard with a delayed explosion
Workload identity federation	Federated credential on the app: issuer vstoken.dev.azure.com, subject sc://org/project/name	ADO presents a token; Entra trusts it. No secret in a drawer

Architecture B — WIF first, then least privilege

Constraint	Default	Reject
Auth mode	Azure RM service connection + Workload identity federation	Automatic wizard that creates subscription Owner + client secret
Scope	Contributor on rg-day63 (or the lab RG that pipeline deploys)	Owner on the subscription so ARM never fails
Automatic vs manual	Automatic is fine if you immediately inspect the SP roles	Never looking at what the wizard granted
One connection	lab-sc for lab RG. Prod later gets a different connection (Day 69)	A single connection named azure that can see every RG
Day 61 app	You may reuse day61-lab and add a federated credential	Creating a secret on day61-lab because the UI offered it

Architecture C — pitfalls that mint master keys named 'Azure Resource Manager'

Pitfall	What you see	Fix
Owner SPN	Role assignments on the subscription for the new app	Delete Owner; assign Contributor (or less) on one RG
Secret-based connection	Expiry date; password rotation theatre	Recreate as WIF. Federated credentials, not client secrets
Confusing connection with registration	Cannot find the connection in Entra	ADO project settings. Entra has the app/SP only
Subject mismatch	WIF token rejected (AADSTS / federated identity error)	Subject sc://<org>/<project>/<connection> must match the federated credential
User PAT in a script	az login with a human, then hope	Jobs use the service connection. Humans use their user

One-liner to remember

Service principals are robot employees — give them a badge scoped to one floor, not master keys. The service connection is the badge; the Entra app is the employee file.

Step-by-step lab (personal Azure / Azure DevOps only)

Personal Azure DevOps org, project azure-100-labs. Personal tenant. Prefer workload identity federation.

- 1 Project Settings → Service connections → New → Azure Resource Manager. Choose Workload identity federation (automatic is OK). Name lab-sc. Subscription = personal.
- 2 Open the connection → Manage Service Principal (or Entra). Note appld. This is the registration/SP. The connection object stays in ADO — two places, not one.
- 3 In Azure: az role assignment list --assignee <appld>. If you see Owner at subscription, treat it as a finding. az role assignment create Contributor on rg-day63 and remove Owner if you can.
- 4 If the UI created a client secret instead of WIF, delete that secret after switching to federated credential (Certificates & secrets → Federated credentials). Issuer <https://vstoken.dev.azure.com/<org>>.
- 5 Queue a trivial pipeline job that uses azureSubscription: lab-sc (AzureCLI@2 az group list). Prove the robot works without your user password.
- 6 Write docs/sc-day63.md: connection name, appld, roles, WIF vs secret. One connection per environment is the habit; today you have lab only.

Starter YAML — the connection name is the badge

```
pool:
  vmImage: ubuntu-latest
steps:
- task: AzureCLI@2
  inputs:
    azureSubscription: lab-sc    # ADO service connection, not the Entra client ID
    scriptType: bash
    scriptLocation: inlineScript
    inlineScript: |
      az account show --query name -o tsv
      az group list --query "[].name" -o tsv
# Federated credential subject (Entra, on the app):
#   sc://<org>/<project>/lab-sc
# Role (Azure): Contributor on /subscriptions/<sub>/resourceGroups/rg-day63
```

Done checklist

- Can separate app registration, service principal, and service connection in one breath
- lab-sc uses WIF (or you documented why not)
- Robot is not Owner on the subscription
- A pipeline job actually used the connection

Tomorrow — Day 64

Azure Key Vault — hotel safe, not a postcard in git